

Turbos Pump Audit Report

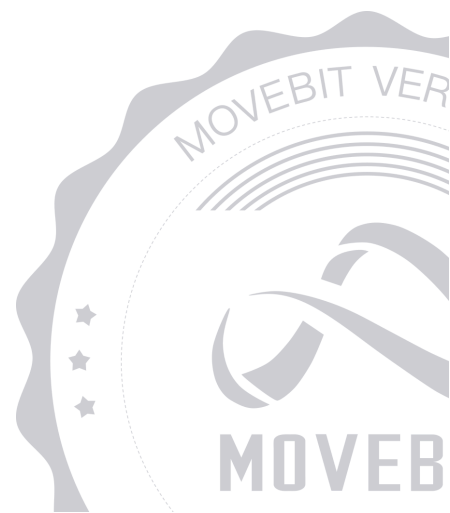


contact@bitslab.xyz



https://twitter.com/movebit_

Wed Oct 16 2024



Turbos Pump Audit Report

1 Executive Summary

1.1 Project Information

Description	Meme pump platform.
Type	DeFi
Auditors	MoveBit
Timeline	Thu Oct 10 2024 - Wed Oct 16 2024
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/turbos-finance/turbos-pump
Commits	d0c0ef13cc319696de9b605b3245ee70f96133a3662821f6fd721f89fe496dcdee3fbb5cc1408e53

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
CUR	sources/curves.move	0d8f8a9731c0bc150508543781adc d04381aae67
FMU6	sources/full_math_u64.move	fc7d8dfc94b7b53cd97c9340d2696 2527e09f3ea
TUR	sources/turbospump.move	5bc8ec10f5024a0ffaa30fa2d420bf a8ec06d4e1
TUR	sources/turbospump.move	857757b22e7a90d97a1e3034043c 82c96833115f

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	8	8	0
Informational	1	1	0
Minor	3	3	0
Medium	3	3	0
Major	1	1	0
Critical	0	0	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the "**Testing and Automated Analysis**", "**Code Review**" and "**Formal Verification**" strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by [Turbos](#) to identify any potential issues and vulnerabilities in the source code of the [Turbos Pump](#) smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 8 issues of varying severity, listed below.

ID	Title	Severity	Status
TUR-1	<code>virtual_token_reserves</code> is Double Counted	Major	Fixed
TUR-2	No Limit On <code>deployment_fee</code>	Medium	Fixed
TUR-3	Lp Value Checking Is Not Working	Medium	Fixed
TUR-4	<code>buy_with_return</code> Potentially May Not Check if amount Is Less Than <code>available_token_amount</code>	Medium	Fixed
TUR-5	Recommend Destroying <code>TreasuryCap</code> Instead of transferring to <code>0x0</code>	Minor	Fixed
TUR-6	<code>update_package_version</code> Issue	Minor	Fixed
TUR-7	<code>sell_with_return</code> Has No Limit On <code>token_amount_to_sell</code>	Minor	Fixed
TUR-8	Possible Spellings	Informational	Fixed

3 Participant Process

Here are the relevant actors with their respective abilities within the [Turbos Pump Smart Contract](#) :

Owner

- The owner can call the `update_config` to update the info of the pool.
- The owner can call the `collect_protocol_fee` function to collect the protocol fee.
- The owner can update the configuration via the `update_config` function.
- The owner can transfer owner permissions through the `transfer_admin` function.

User

- Users can call the `create` function to create a new pool.
- Users can call the `buy / sell` function to buy or sell the coin `T`.

4 Findings

TUR-1 `virtual_token_reserves` is Double Counted

Severity: Major

Status: Fixed

Code Location:

`sources/turbospump.move#284`

Descriptions:

The calling order in the `buy()/sell()` function is to call the `swap()` function first and then update `virtual_token_reserves`. Inside the `swap` function, `virtual_token_reserves` will subtract `token_amount` from the `token_coin` amount entered by the user. The second calculated value outside the `swap()` function continues to subtract `coin::value<T>`. Therefore, `virtual_token_reserves` will actually be subtracted twice, resulting in inaccurate calculation of the reserve amount. This logical error may affect subsequent transactions and the status of the liquidity pool.

```
if (coin::value<T>(&token_coin) > 0) {  
    pool.virtual_token_reserves = pool.virtual_token_reserves - token_amount;  
};  
if (coin::value<SUI>(&sui_coin) > 0) {  
    pool.virtual_sui_reserves = pool.virtual_sui_reserves - sui_amount;  
};  
...  
  
pool.virtual_token_reserves = pool.virtual_token_reserves - coin::value<T>  
(&bought_token_coin);  
...  
pool.virtual_sui_reserves = pool.virtual_sui_reserves - coin::value<SUI>  
(&sui_coin_returned);
```

Suggestion:

It is recommended to update `virtual_token_reserves` once, or integrate the code into the `swap()` function.

TUR-2 No Limit On deployment_fee

Severity: Medium

Status: Fixed

Code Location:

`sources/turbospump.move#369`

Descriptions:

When creating the pool, there is no limit to the specific cost of the `deployment_fee` , resulting in users being able to pass in zero coins then bypassing the fee charge.

Suggestion:

It is recommended that the create function charge a fixed fee.

TUR-3 Lp Value Checking Is Not Working

Severity: Medium

Status: Fixed

Code Location:

`sources/turbospump.move#188`

Descriptions:

`check_lp_value_is_increased_or_not_changed` ensures that the constant K is incremented after the swap, but the function didn't take the correct argument. In the `swap` function, the function can pass the `assert` check with any value of `token_amount` or `sui_amount`, causing the `check_lp_value_is_increased_or_not_changed` function's check to be meaningless.

Suggestion:

It is recommended that this be changed to the correct checking logic.

TUR-4 `buy_with_return` Potentially May Not Check if amount Is Less Than `available_token_amount`

Severity: Medium

Status: Fixed

Code Location:

`sources/turbospump.move#252`

Descriptions:

The `buy_with_return` function does not check if the `amount` is less than the `available_token_amount` for cases where the user has set `is_exact_in` to true, resulting in more than the expected number of token `T` that should be sold, besides, it may result in the computational of line 248 underflow.

Suggestion:

It is recommended that all cases be limited to less than `available_token_amount`.

TUR-5 Recommend Destroying TreasuryCap Instead of transferring to 0x0

Severity: Minor

Status: Fixed

Code Location:

`sources/turbospump.move#367`

Descriptions:

To prevent any further minting and burning, it's recommended to call `treasury_into_supply` to destroy the `TreasuryCap` and lock the `supply` into the contract.

Suggestion:

It's recommended to call `treasury_into_supply` to destroy the `TreasuryCap` and lock the `supply` into the contract.

TUR-6 `update_package_version` Issue

Severity: Minor

Status: Fixed

Code Location:

`sources/turbospump.move#156`

Descriptions:

The `migrate_version` function can upgrade the version field in `config`. However, the function should not set the value of the `new_version` by the function parameter, but by the constant `VERSION` of the new contract.

Suggestion:

It is recommended to ensure that this is as designed or modified to use `VERSION` constants or limit the version field to be greater than the current version.

TUR-7 `sell_with_return` Has No Limit On `token_amount_to_sell`

Severity: Minor

Status: Fixed

Code Location:

`sources/turbospump.move#430`

Descriptions:

The `sell_with_return` function calculates how much the user actually needs to sell without ensuring that the user has a sufficient amount of `token_coin`, resulting in the user being able to withdraw the coin directly from the pool.

Suggestion:

It is recommended to add a check to ensure that the user has enough `token_coin`.

TUR-8 Possible Spellings

Severity: Informational

Status: Fixed

Code Location:

`sources/turbospump.move#527`

Descriptions:

Should single `combined_token_teserves` be `combined_token_reserves` , which may be an unexpected spelling.

Suggestion:

It is recommended to change the variable name to `reserves` .

Resolution:

The client adopted our suggestions

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

